HCI711S · Lab 2 · NUST Cyber Security

Social Engineering Attack

Phishing Simulation on Bank Windhoek

Exploiting Cialdini's Principles of Authority & Scarcity

HCI711S · Human Computer Interaction Security
10 April 2026

Group Members

Rainhold Kaurembi 223002038
Stella Apollus 222045868
Titus Shaangelo 222084774

Faculty of Computing and Informatics
Department of Cyber Security

01 Introduction

Overview of the simulation and organization

About Bank Windhoek

Bank Windhoek is one of Namibia's leading commercial banks, headquartered in Windhoek. It serves thousands of individual and corporate clients across the country.

Key Business Processes:

- Online and mobile banking services
- Retail and corporate lending
- Employee portal for internal HR and finance
- Customer account management
- Inter-branch fund transfers

The bank employs over 1,500 staff across its branches, all of whom use the internal employee web portal for daily operations — making it a prime social engineering target.

Social Engineering Technique

Definition: Phishing is the deceptive impersonation of a trusted source to steal sensitive credentials.

Execution: A **Spear Phishing** attack using the **Social-Engineer Toolkit (SET)** to clone a Bank Windhoek Google login.

Why it Succeeds: The combination of familiar branding and a high-pressure scenario effectively lowers user vigilance and bypasses security intuition

02 Cialdini's Principles Exploited

The psychological levers used in this phishing attack

AUTHORITY

EXPLOITED

Exploitation of Institutional Trust and Impersonating “Gatekeepers”

- Mimicking IT and HR exploits the built-in trust and respect employees have for administrative leadership

Professional Legitimacy

- Using formal banking terminology creates a “Halo Effect” that makes the fake request feel like a routine corporate process

Inhibited Skepticism

- Socially conditioned obedience to “experts” overrides security intuition, leading to compliance without questioning the source.

SCARCITY

EXPLOITED

Exploiting Loss Aversion

- Threatening account deactivation triggers fear of work disruption, making users act quickly to avoid losing access.

Triggering Reactive Thinking

- The strict deadline induces “ System 1” thinking, causing victims to overlook red flags like suspicious URLs

Forced Shortcut Behavior

- Artificial urgency makes following safe security habits feel “too slow”, pressuring victims to make the risky, immediate path

FEAR

EXPLOITED

Fear of Professional Consequences

- Utilizes the fear of Superior management to bypass logic victim prioritizes avoiding punishment over verifying the emails legitimacy

Operational Lockout

- The treat of an “immediate account suspension” create a state of panic leading to an alternative to stay active

Fear of Non- Compliance

- They comply because they fear being identified as the “weak link” in the organization's security chain.

03 Attack Flow & Methodology

Step-by-step phishing campaign execution

01 Reconnaissance

Attacker researches Bank Windhoek's email format (firstname.lastname@bankwindhoek.com.na) and identifies the IT Security team name from LinkedIn/website.

02 Email Crafted

Spear-phishing email created impersonating IT Security. Sender domain: it-security@bankwindhoek-verify.com. Subject: URGENT: Employee Portal Account

Suspended.

03 Email Deployed

Email sent to all employees via Social Engineering toolkit. It includes a countdown timer (2 hours), threats of HR escalation, and a Verify Account button linking to the fake portal.

04 Credential Harvest

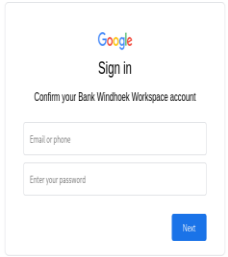
Employee clicks the link, lands on a cloned Bank Windhoek employee login page. They enter their Employee ID, password and.

05 Outcome

Victim: Alert page shown + mandatory training enrollment. Reporter: Certificate of Security Awareness issued by IT Security Division.

04 The Phishing Email

Anatomy of the social engineering email sent to employees



Bank Windhoek Corporate Mail

BANK WINDHOEK Employee Security Portal

RE: ACCOUNT VERIFICATION

To laylabankwindhoek@gmail.com

Cc Bcc

RE: ACCOUNT VERIFICATION

Dear Bank Windhoek Employee,

As part of our **2026 Cyber Security Audit** and the recent upgrade to our internal data protection protocols, all employees in the IT, HR, Finance, and Executive departments are required to re-verify their Google Workspace credentials.

This verification ensures that your account remains compliant with the new banking security standards and prevents unauthorized access to sensitive financial data.

Action Required: Please log in to the secure Bank Windhoek Verification Portal below to confirm your account status:

👉 Confirm Credentials Here

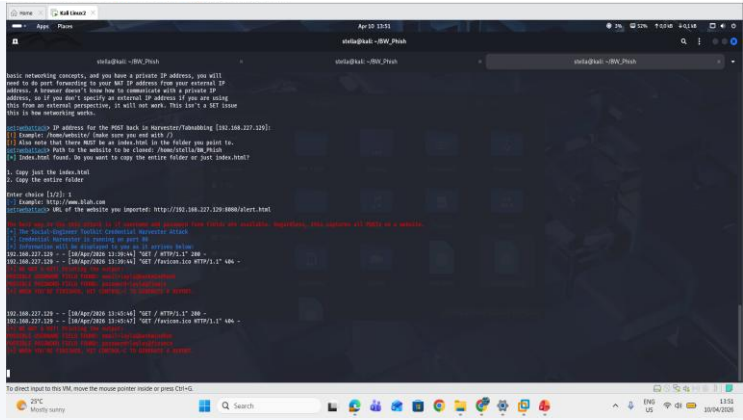
Deadline: To avoid a temporary service disruption and account lockout, please complete this verification by **4:00 PM today, April 10, 2026**.

Thank you for your cooperation in keeping Bank Windhoek secure.

Regards, Mr. P. Katambo Head of Information Security *Bank Windhoek Namibia*

Sans Serif

Send



🏆 **CONGRATULATIONS!**

You correctly identified this as a Social Engineering attack.

Reward: You have been awarded the Bank Windhoek Cyber Champion Certificate.

ðŸ›¡ SECURITY ALERT: BANK WINDHOEK ðŸ›¡

This was a simulated Phishing Attack for training purposes.

You just entered your corporate credentials into an unverified site.

Please report this to the IT Security Team immediately.

05 Employee Outcomes

Two outcomes based on how the employee responds to the phishing email

⚠ Fell for the Attack

What happens:

→ Employee clicks the phishing link
→ Enters credentials on the fake portal
→ Credentials sent to attacker's server
→ Redirected to a Security Alert page

Alert page informs the employee:

- They were victims of a phishing test
- What red flags they missed
- What they should have done instead

Consequence:

- Mandatory Security Awareness Training
- Line manager notified
- Incident logged in IT Security system
- Re-tested in 30 days

VS

✓ Successfully Identified & Reported

What happens:

→ Employee notices suspicious sender domain
→ Does NOT click the link
→ Reports email to it-security@bankwindhoek.na
→ IT team confirms the phishing simulation

Certificate of Security Awareness issued:

- Named certificate signed by IT Security Lead
- Employee recognized in company newsletter
- Certificate added to HR training record

Recognition:

- Commendation from CISO
- Listed as Phishing Champions
- Used as peer trainer for colleagues

06 Mitigation Techniques

Security controls to prevent and reduce phishing attack success rates

Email Authentication (SPF / DKIM / DMARC)

Configure SPF, DKIM and DMARC records on bankwindhoek.com.na. This prevents attackers from spoofing the official domain. DMARC rejects or quarantines emails failing authentication.

Security Awareness Training

Conduct quarterly phishing simulations and mandatory training. Teach employees to inspect sender domains, hover over links, and verify urgent requests through official channels.

Multi-Factor Authentication (MFA)

Even if credentials are harvested, MFA (OTP via mobile or authenticator app) prevents unauthorized portal access. Implement MFA on all employee-facing systems.

Email Gateway Filtering

Deploy advanced email security (e.g. Proofpoint, Mimecast) to block phishing domains, malicious links, and impersonation attempts before they reach employee inboxes.

Incident Reporting Culture

Establish a simple one-click report phishing button in the email client. Reward reporters. Create a no-blame culture so employees feel safe reporting suspicious messages.

Zero Trust & Least Privilege

Implement Zero Trust Architecture. Limit what credentials can access. Even compromised credentials should not expose critical systems without additional context-based verification.

07 Conclusion & Key Takeaways

Human Factor is the Weakest Link

Technical controls alone are insufficient. Employees remain the primary attack surface in social engineering.

Authority + Scarcity = High Success Rate

Combining these two Cialdini principles creates powerful psychological pressure that bypasses rational judgment.

Awareness Training is Essential

Regular phishing simulations and training significantly reduce susceptibility rates over time.

Reward Vigilance, Don't Punish Mistakes

A positive security culture where reporters are celebrated creates a stronger organizational defense.

Layered Defense Works Best

Email authentication, MFA, filtering, and training together form a comprehensive defense-in-depth strategy.

HCI711S – Human Computer Interaction Security

Data Anonymization

Lab 2 – Part B: Technical Implementation of Privacy Techniques

Techniques Covered: Data Masking | Pseudonymization

Stella Apollus 222045868
Titus Shaangelo 222084774
Rainhold Kaurembi 223002038

Presentation Overview

01

What is Data Anonymization?

Definition, importance, and the 8 core techniques

02

Technique 1: Data Masking

How masking works, use cases, implementation

03

Technique 2: Pseudonymization

Token-based replacement, key management

04

Dataset & Implementation

Sample dataset, SQL results, before/after comparisons

05

Attacks on Anonymization

Re-identification, inference, linkage attacks

06

Mitigations & Recommendations

Defence strategies, best practices

What is Data Anonymization?

Data anonymization is the process of removing or modifying personally identifiable information (PII) from datasets, making it impossible or very difficult to re-identify the individuals to whom the data belongs.

Legal Compliance

GDPR, HIPAA, POPIA and other regulations require PII protection before sharing data.

Data Utility

Enables analysis, research, and AI training while preserving privacy—data is still usable.

Risk Reduction

Minimizes breach impact—even if stolen, anonymized data cannot expose individuals.

This lab focuses on two techniques: Data Masking (Technique 08) and Pseudonymization (Technique 04).

Technique 1: Data Masking

Definition

Data Masking replaces real sensitive values with fictitious but structurally realistic data. The format is preserved (e.g., phone numbers still look like phone numbers) but the values are permanently altered.

Key Properties

- Format-preserving (structural integrity maintained)
- Irreversible – original data cannot be recovered
- Suitable for non-production environments (dev/test)
- Applied at field/column level in databases

Example – Before vs After Masking

Field	Original	Masked
Name	Maria Nakamura	****** ********
Email	m.nakamura@bank.na	****@****.na
Phone	+264 81 234 5678	+264 ** *** ****
ID No.	9301015800083	XXXXXXXXXXXXX
Card No.	4111 1111 1234 5678	**** **** **** 5678
Salary	N$ 45,000	N$ XXXXX

Technique 2: Pseudonymization

Definition

Pseudonymization replaces direct identifiers (names, IDs) with artificial identifiers (pseudonyms/tokens). Unlike masking, the original data can be re-linked via a secure mapping table – but only by authorized parties holding the key.

Key Properties

- Reversible with the mapping key (controlled re-identification)
- Recognized by GDPR as a risk-reduction measure
- Suitable for production analytics & research
- Tokens are typically generated using hashing or UUID

How Pseudonymization Works

1. Identify direct identifiers (Name, ID, Email)
2. Generate a unique token / UUID per record
3. Replace identifiers with tokens in dataset
4. Store original → token mapping in secure vault
5. Analysts use tokenized dataset safely
6. Re-identification only possible with secure key

Dataset Description

Database	Table	Records	Domain
MySQL 8.0	customer_records	500 rows	Retail Banking

Raw Dataset (sample – 6 rows):

CustomerID	Full Name	Email	Phone	NatID	Account	Balance
C001	Anna Shikongo	anna.s@mail.na	+264811234	9801015800012	ACC-884123	N$12,400
C002	James Hamutenya	j.ham@mail.na	+264812345	8907025800035	ACC-991234	N$8,750
C003	Grace Nghidipo	g.nghi@mail.na	+264813456	0102035800048	ACC-112345	N$31,200
C004	Peter Katjimune	p.kat@mail.na	+264814567	9504045800061	ACC-223456	N$5,100
C005	Sofia Amupolo	s.amu@mail.na	+264815678	0006055800074	ACC-334567	N$19,800
C006	David Nghifikwa	d.ngh@mail.na	+264816789	8803065800087	ACC-445678	N$7,350

⚠ *All records above contain real-format PII — anonymization is mandatory before sharing.*

Implementation: Data Masking

SQL Implementation:

```sql
-- Step 1: Create masked copy of table
CREATE TABLE customer_masked AS
SELECT
  CustomerID,
  CONCAT(REPEAT('*', CHAR_LENGTH(FullName)-3),
    RIGHT(FullName,3)) AS FullName,
  CONCAT(LEFT(Email,1),'****',
    SUBSTRING_INDEX(Email,'@',-1)) AS Email,
  CONCAT(LEFT(Phone,5),'*****') AS Phone,
  CONCAT('XXXXXXXXX', RIGHT(NatID,4)) AS NatID,
  CONCAT('ACC-XXXXX') AS AccountNo,
  Balance
FROM customer_records;
```

After Masking (sample rows):

CustomerID	FullName	Email	NatID
C001	***ngo	a****mail.na	XXXXXXXXX0012
C002	****nya	j****mail.na	XXXXXXXXX0035
C003	*****po	g****mail.na	XXXXXXXXX0048
C004	*****ne	p****mail.na	XXXXXXXXX0061
C005	****olo	s****mail.na	XXXXXXXXX0074

1. Export production table to test schema
2. Apply SQL masking transformations field-by-field
3. Validate format integrity (regex checks)
4. Confirm original table untouched, share masked copy

Implementation: Pseudonymization

Python Implementation:

```python
import pandas as pd, uuid, hashlib


# Load dataset
df = pd.read_csv('customer_records.csv')
mapping = {}  # Secure mapping table


def pseudonymize(value):
    token = str(uuid.uuid4())[:8].upper()
    mapping[token] = value
    return token


# Apply pseudonymization
df['Name_Token']    = df['FullName'].apply(pseudonymize)
df['Email_Token']   = df['Email'].apply(pseudonymize)
df['NatID_Token']   = df['NatID'].apply(pseudonymize)
df_anon = df.drop(columns=['FullName','Email','NatID'])
df_anon.to_csv('customer_pseudonymized.csv', index=False)
```

1. Load dataset and define identifier columns
2. Generate UUID-based token per unique value
3. Replace PII columns with tokens in output file
4. Store mapping securely – never bundle with dataset

After Pseudonymization:

CustID	Name_Token	NatID_Token
C001	A3F8-92BC	D71E-44CF
C002	B9D2-17AE	C83A-56BD
C003	E40F-83DA	F15C-29GH
C004	G62H-71KL	H93I-08MN
C005	I27J-46OP	J58K-37QR

🔑 *Mapping key (token → real value) stored in encrypted vault, access-controlled, separate from dataset.*

Attacks on Anonymization Techniques

Data Masking

⚠ Pattern Inference

If format is preserved, attacker can narrow down identity using public records (e.g., phone prefix + area reveals region).

⚠ Partial Re-identification

Retaining last 4 digits of ID/card can be combined with leaked data to re-identify individuals.

⚠ Auxiliary Data Linkage

Combining masked dataset with external datasets (social media, govt records) to cross-match individuals.

Pseudonymization

⚠ Key Compromise Attack

If the mapping vault is breached, all pseudonyms can be reversed — full re-identification becomes trivial.

⚠ Frequency Analysis

If a token always maps to the same real value, frequency distribution reveals patterns and enables inference.

⚠ Record Linkage Attack

Quasi-identifiers (age, gender, city) combined across two pseudonymized datasets can re-identify individuals.

Mitigations & Best Practices

Encrypt Mapping Vaults

Use AES-256 encryption for pseudonym mapping tables. Store keys in HSM (Hardware Security Module) separate from data.

Add Noise / Perturbation

Combine masking with data perturbation – add small random offsets to numeric values to prevent exact pattern matching.

Apply k-Anonymity

Ensure each record is indistinguishable from at least k-1 others by generalizing quasi-identifiers (e.g., age ranges instead of exact ages).

Suppress Rare Values

If a combination of fields uniquely identifies a record, suppress or generalize those values before release.

Privacy Risk Audits

Regularly test anonymized datasets using re-identification tools (e.g., ARX, sdcMicro) to quantify re-identification risk.

Legal & Policy Controls

Enforce data sharing agreements, minimum data access principles, and GDPR/POPIA-aligned data governance policies.

Comparison & Conclusion

Criteria	Data Masking	Pseudonymization
Reversibility	❌ Irreversible	✅ Reversible (with key)
GDPR Recognition	✅ Compliant	✅ Explicitly recognized
Use Case	Dev / Testing environments	Production analytics & research
Re-identification Risk	Low (format preserved = moderate)	Low if key is secure
Performance Impact	Low	Low to moderate
Complexity	Simple SQL transformations	Requires token store & key mgmt

Key Takeaways

- No single technique is perfect – layering masking + pseudonymization maximises protection.
- Anonymization must be validated using risk-scoring tools before data is shared.
- Legal compliance (GDPR, POPIA) and governance policy must accompany technical controls.

References

[1] European Parliament. (2016). General Data Protection Regulation (GDPR) – Article 4 & Recital 26.

[2] GeeksforGeeks. (2025). Data Anonymization Techniques. https://www.geeksforgeeks.org/data-anonymization/

[3] Sweeney, L. (2002). k-Anonymity: A Model for Protecting Privacy. International Journal on Uncertainty, Fuzziness and Knowledge-Based Systems.

[4] ENISA. (2016). Privacy by Design in Big Data. European Union Agency for Cybersecurity.

[5] Prasser, F. & Kuhn, K. A. (2014). ARX – A Comprehensive Tool for Anonymizing Biomedical Data. AMIA Annual Symposium.

[6] NIST SP 800-188. (2023). De-Identifying Government Datasets – Second Draft. National Institute of Standards and Technology.